

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

FRIDAY, DECEMBER 15, 2006

Top 10 Web Hacks of 2006

Update: RSnake provides [his summary of the Top 10](#). Insightful as usual.

Attacks always get better, never worse. That's what probably what I'll remember most about 2006. What a year it's been in web hacking! There's never been such a big leap forward in the industry and frankly it's really hard to keep up. My favorite quote came today from Kryan:

"The last quarter of this year, RSnake and Jeremiah pretty much destroyed any security we thought we had left. Including the "I'll just browse without javascript" mantra. Could you really call that browsing anyways?"

To look back on what's been discovered [RSnake](#), [Robert Auger](#), and myself collected as many of the new 2006 web hacks as we could find. We're using the term "hacks" loosely to describe some of the more creative, useful, and interesting techniques/discoveries/compromises. There were about 60 to choose from making the selection process REALLY difficult. After much email deliberation we believe we created a solid Top 10. Below you'll find the entire list in no particular order. Enjoy!

Top 10

1. Web Browser Intranet Hacking / Port Scanning - *(with JavaScript and with HTML-only and the improved model)*
2. Internet Explorer 7 "mhtml:" Redirection Information Disclosure
3. Anti-DNS Pinning and Circumventing Anti-Anti DNS pinning
4. Web Browser History Stealing - *(with CSS, evil marketing, JS login-detection, and authenticated images)*
5. Backdooring Media Files *(QuickTime, Flash, PDF, Images, Word [2], and MP3's)*
6. Forging HTTP request headers with Flash
7. Exponential XSS
8. Encoding Filter Bypass (UTF-7, Variable Width, US-ASCII)
9. Web Worms - *(AdultSpace, MySpace, Xanga)*
10. Hacking RSS Feeds

Honorable Mention

- Stealing User Information Via Automatic Form Filling
- Advanced Web Attack Techniques using Gmail *(Overwriting the Array Constructor)*
- Google Vulnerable Code Dork



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

Posts

Comments

Full List

The Attack of the TINY URLs
Backdooring MP3 Files
Backdooring QuickTime Movies
CSS history hacking with evil marketing
I know where you've been
Stealing Search Engine Queries with JavaScript
Hacking RSS Feeds
MX Injection : Capturing and Exploiting Hidden Mail Servers
Blind web server fingerprinting
JavaScript Port Scanning
CSRF with MS Word
Backdooring PDF Files
Exponential XSS Attacks
Malformed URL in Image Tag Fingerprints Internet Explorer
JavaScript Portscanning and bypassing HTTP Auth
Bruteforcing HTTP Auth in Firefox with JavaScript
Bypassing Mozilla Port Blocking
How to defeat digg.com
A story that diggs itself
Expect Header Injection Via Flash
Forging HTTP request headers with Flash
Cross Domain Leakage With Image Size
Enumerating Through User Accounts
Widespread XSS for Google Search Appliance
Detecting States of Authentication With Protected Images
XSS Fragmentation Attacks
Poking new holes with Flash Crossdomain Policy Files
Google Indexes XSS
XML Intranet Port Scanning
IMAP Vulnerable to XSS
Detecting Privoxy Users and Circumventing It
Using CSS to De-Anonymize
Response Splitting Filter Evasion
CSS History Stealing Acts As Cookie
Detecting FireFox Extensions
Stealing User Information Via Automatic Form Filling
Circumventing DNS Pinning for XSS
Netflix.com XSRF vuln
Browser Port Scanning without JavaScript
Widespread XSS for Google Search Appliance
Bypassing Filters With Encoding
Variable Width Encoding
Network Scanning with HTTP without JavaScript
AT&T Hack Highlights Web Site Vulnerabilities
How to get linked from Slashdot
F5 and Acunetix XSS disclosure
Anti-DNS Pinning and Circumventing Anti-Anti DNS pinning
Google plugs phishing hole
Nikon magazine hit with security breach
Governator Hack
Metaverse breached: Second Life customer database hacked
HostGator: cPanel Security Hole Exploited in Mass Hack
I know what you've got (Firefox Extensions)
ABC News (AU) XSS linking the reporter to Al Qaeda
Account Hijackings Force LiveJournal Changes
Xanga Hit By Script Worm
Advanced Web Attack Techniques using GMail
PayPal Security Flaw allows Identity Theft
Internet Explorer 7 "mhtml:" Redirection Information Disclosure
Bypassing of web filters by using ASCII
Selecting Encoding Methods For XSS Filter Evasion
Adultspace XSS Worm
Anonymizing RFI Attacks Through Google
Google Hacks On Your Behalf
Google Dorks Strike Again

Posted by [Jeremiah Grossman](#) at [2:08 PM](#)

Labels: [top 10 web hacks 2006](#)

3 comments:

Anonymous said...

heh, i think you guys nailed what those top 10 should be - although i think either of the first two honorable mentions could oust the RSS feed hacking..

It's also nice to just have the links for all the big (60, not 10) hacks and attacks of the year. And interesting to note that most all of them occurred in August-December

[December 15, 2006 at 3:31 PM](#)

Anonymous said...

The amount of Remote Code Execution, SQL injection and other Highly Critical Vulnerabilities in Web Apps, discovered this year is huge!

[December 18, 2006 at 3:20 PM](#)

[auto loan rates](#) said...

i am very grateful to you for this kind information and say thanks to you for sharing this list.

[August 21, 2009 at 2:03 AM](#)

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)